

ARCHITECTURE OF DIGITAL SAFETY

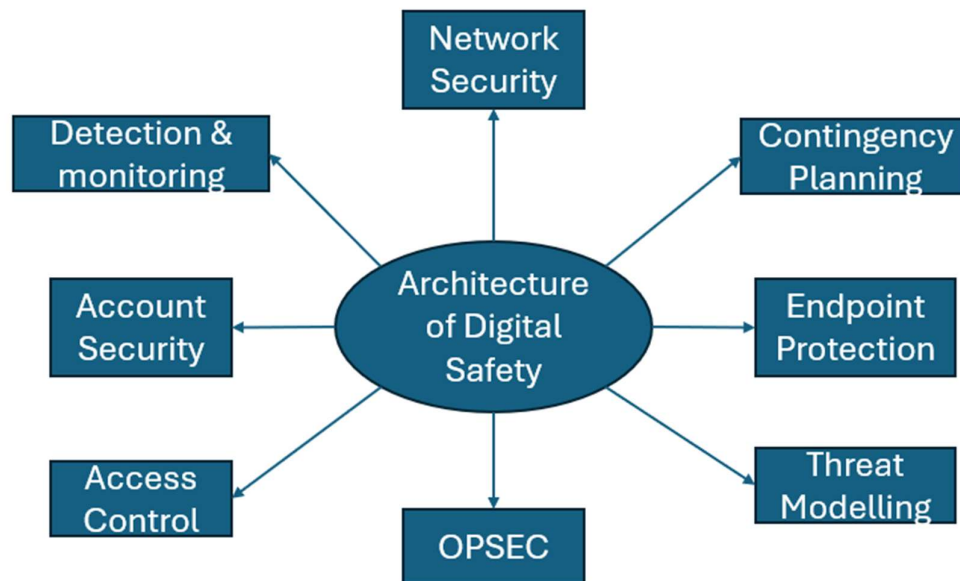
Contents

Introduction	2
Architecture Mindset	3
Account Security Domain	4
Network Security Domain	5
Operational Security Domain	6
Endpoint Protection Domain	7
Threat Modelling Domain	8
Detection & Monitoring Domain	9
Access Control Domain	10
Personal Contingency Planning Structure	11
Organisation Contingency Planning Structure	12
Human Layer Section.....	13
Security System Example	14
Security Architecture Trade-Offs	15

Introduction

The architecture of safety is a security architecture that is built on the assumption that a system can always be breached. The architecture is built on multiple layers that are combined to protect a system from a variety of threats. This is what most technical experts would call defence in depth. This is because every time a new layer is added to a security system it raises the cost, resources and time needed to breach a system. This directly adapts security systems against an attacker's intent, which is to gain unauthorised access to a system without being detected. This architecture also suggests that a user should always plan for if a breach does happen. Contingency plans for breaches should be structured, realistic and easy to follow under stress.

While this architecture cannot provide a perfectly secured system, it can provide users with a real sense of safety and allow for organisations to comply with legal requirements like the GDPR and Data Protection Act. The core idea of this architecture is to provide a clear and structured framework for users to design their own security systems based on their own needs. This benefits a user because it allows them to design and adapt their security system based on their own resources and schedule. This architecture suggests that security is a continuous and evolving process. Security is not a one-time set-up. Do not blindly trust this architecture. Like any other system, this architecture can be wrong. Make sure to test it and adapt it to your own security needs.



The spider diagram above shows the domains and cybersecurity concepts that this security architecture will cover. This architecture will also include an example, trade-offs and video links for learning concepts. You can read for more information in the sections below.

Architecture Mindset

- **Mindset is important for building security systems as you must understand how to think like a defender and an attacker.**
- **This architecture uses a balanced mindset of an attacker and a defender for max effective in creating robust security systems.**
- **I will first discuss how to think like a defender.**
- **First, you must understand what system you are defending so you know where to focus protections.**
- **This is important because if you don't know the system you are defending then you won't be able to defend it well.**
- **Second, you must know what resources you have available and what your threat model is.**
- **This is important because a threat model allows you to focus protections and knowing your resources allows you to use them effectively.**
- **Third, you must learn to design a system that combines all the protections you have researched or learned.**
- **This is important because security systems that are multi-layered and robust are the most effective in the real-world.**
- **Fourth, you must be ready to constantly adapt against new threats or threat models that you may face.**
- **This is important as static security systems are more likely to be compromised while the multi-layered and adaptive systems are less likely to be compromised.**
- **Now I will discuss how to think like an attacker.**
- **First, you must understand the system you are attacking or trying to exploit so you know where to focus.**
- **This is important because you are more likely to find vulnerabilities in a system you understand.**
- **Second, you must know what exploits and tools you have available.**
- **This is important because you know what vulnerabilities you can exploit in a system and what vulnerabilities you can't.**
- **Third, you must find ways to exploit systems in the connections or the methods used to make the systems work for users on a daily occasion.**
- **This is important because it is easier to find an exploit in the areas or features that weren't designed with security in mind.**
- **Finally, you must be ready to adapt against new protections or detection features as defenders are always updating.**
- **This is important because while some security systems stay static, the highest value and most rewarding systems are always adapting.**
- **This mindset cannot promise perfect exploitation or finding gaps in systems, but it can improve your exploitation and vulnerability scanning skills.**
- **The attacker mindset is not encouraged to be used for hacking systems you do not own.**

Account Security Domain

- **Account Security is the process of securing your account from unauthorized access.**
- **Account Security is important as sensitive data such as personal information or projects can be exposed if an attacker were to gain access to your account.**
- **There are 4 main protections you can use to protect your account from an attacker.**
- **The first protection is strong passwords.**
- **This protection means using complex and unique passwords for each account to prevent an attacker from using brute force.**
- **I would recommend using 12-16 characters with a mixture of characters, numbers and symbols for each account.**
- **You can use password managers such as Bitwarden, 1Password or Proton pass for easier and more reliable management of passwords.**
- **The second protection is MFA (Multi-factor authentication)**
- **This protection means using a second layer of authentication on each account that prevents an attacker from accessing even with your password.**
- **I would recommend using MFA via authentication app or via hardware key for as many accounts as possible.**
- **There are also other MFA options available such as email-based or SMS-based however these are outdated and vulnerable to attacks.**
- **You can use authentication apps like Google authenticator, Microsoft Authenticator or Authy.**
- **The third protection is encrypted recovery codes.**
- **This protection means ensuring that an attacker cannot use the recovery mechanisms to gain access to your account.**
- **I would recommend storing backup recovery codes or kits in encrypted containers or folders and encrypted cloud storage.**
- **There are also other recovery options available like email-based or SMS-based however like MFA they are also vulnerable and outdated.**
- **You can use software like VeraCrypt or 7-zip for encryption while for encrypted cloud storage you can use Proton drive or sync.com.**
- **The fourth protection is app-level passcodes.**
- **This protection means ensuring that any accounts you have connected via apps on your device are secure.**
- **I would recommend either locking the app using a third-party tool, OS authentication on IOS or separate passcode if the app supports it.**
- **You can use third-party tools such as AppLock to ensure that apps are secured correctly.**
- **Make sure to adapt tooling based on your security needs and threat model as tools vary across operating systems and devices.**

Network Security Domain

- **Network Security is the process of securing a network against unauthorized access.**
- **Network Security is important as if an attacker compromises your home network they can access sensitive data or cause disruption to your usual activities.**
- **There are 5 protections that a user or company can implement.**
- **The first protection is Wi-Fi security protocol.**
- **This protection means setting up the protocol to handles the security of data on the network.**
- **I would recommend using WPA3-personal for home networks and small-medium company networks while using WPA3-enterprise for large enterprise networks.**
- **You can use WPA2-personal and enterprise if the router doesn't support WPA3 as it is still considered secure but not as secure as WPA3.**
- **The second protection is turning off remote management.**
- **This protection means disabling a feature that allows someone else to remotely access your router's interface.**
- **I would recommend turning off this feature for both home and company networks unless you have a specific purpose and need for this feature.**
- **This protection can be implemented by going into the router settings and finding the remote management feature toggle or settings.**
- **The third protection is turning off WPS**
- **This protection means disabling a feature that allows you to enter a device into a network via a PIN instead of the network password.**
- **I would recommend turning off this feature for both home and company networks unless you need to set up smart devices.**
- **In the case of smart device setup, you can turn on WPS and then disable it after it is no longer needed.**
- **The fourth protection is secure protocols**
- **This protection means using network protocols that use encryption or authentication to protect access or data.**
- **I would recommend using protocols like TLS, HTTPS, SSH, SFTP and FTPS to ensure that data transfers and web traffic are secured correctly.**
- **This protection can be implemented by ensuring that servers, devices and rarely routers use these protocols.**
- **The fifth protection is VLANs.**
- **This protection means segmenting traffic on a network to isolate and to force an attacker to have to pivot between VLANs to compromise data.**
- **I would recommend using VLANs in large network environments like schools, enterprises or companies.**
- **This protection can be implemented via the router by organising VLANs based on department or activity.**

Operational Security Domain

- **Operational Security is the process of controlling information that others have, and it also serves as the behavioural aspects of security.**
- **Operational Security is important as it limits the information that an attacker can gain about you and reinforces technical security with behavioural security.**
- **There are 5 OPSEC habits/protections you can use.**
- **The first OPSEC habit is avoiding sharing sensitive data publicly on social media or via other methods.**
- **I would recommend avoiding sharing specific sensitive data like location, school, DOB and full name as these can be used by an attacker to compromise you.**
- **This habit can be implemented by turning off location, using limited bio information and usernames instead of real name.**
- **The second OPSEC habit is email separation.**
- **Email separation is where you use different emails for specific accounts or services to prevent a single point of failure.**
- **This is important because if an attacker were to compromise your master email, then they could potentially compromise all accounts you have.**
- **This habit can be implemented by using email services like Gmail, Proton mail, temp mail or outlook spread out across accounts for redundancy.**
- **The third OPSEC habit is opting out known people searching sites.**
- **I would recommend searching up your full name, email address or other identifying information on these sites to see their records about you.**
- **Some known people searching sites include Spokeo, Whitepages, BeenVerified, Intelius and PeopleFinders.**
- **This is important because an attacker can find large amounts of information from these sites which can be used to compromise you.**
- **The fourth OPSEC habit is using separate identities for each account.**
- **I would recommend separating the identities used for your most sensitive accounts to prevent cross-linking.**
- **This is important because it reduces the blast radius if one account is compromised or also makes it more difficult for an attacker to find the account.**
- **This habit can be implemented by using realistic fake names, limited bio, VPN and isolated container to prevent any linkage to other account.**
- **The fifth OPSEC habit is metadata wiping.**
- **Metadata wiping is where you will wipe metadata from files or images before you send them over or post them online.**
- **This is important because an attacker can use metadata to find out information about you and then use it to compromise you.**
- **This habit can be implemented by using built-in metadata wiping tools into Microsoft word or third-party tools like ExifTool to ensure metadata is wiped.**
- **Make sure to adapt the tools and layer the protections as you need.**

Endpoint Protection Domain

- **Endpoint Protection is the process of protecting of your devices from unauthorized access.**
- **Endpoint Protection is important as if your device is compromised then multiple other domains are compromised.**
- **There are 5 main protections you can use to secure your devices.**
- **The first protection is anti-malware software.**
- **This protection means setting up a software program that is specifically designed to deal with malware.**
- **I would recommend using built-in AV like Windows Defender or XProtection or a third-party AV such as Bitdefender or Malwarebytes.**
- **This protection can be implemented mainly by ensuring real-time protection and ensuring that the security settings are configured correctly.**
- **The second protection is device encryption.**
- **This protection means encrypting all the data on your device to ensure that an attacker cannot access your data even if they access the internal drive.**
- **I would recommend using FDE via BitLocker, FileVault, LUKS or VeraCrypt or just device encryption which encrypts the system partition.**
- **This protection can be implemented via the device settings or custom UI in third-party encryption tools.**
- **The third protection is automatic updates.**
- **This protection means ensuring that updates are installed without you manually giving permission to install them.**
- **I would recommend turning on automatic updates for all devices to ensure that your device stays updated with the latest security patches.**
- **This protection can be implemented via the device settings as most operating systems provide the option for automatic updates.**
- **The fourth protection is strong passwords and password policy.**
- **This protection means uses passwords for account authentication that cannot easily be brute forced and setting rules for how passwords are handled.**
- **I would recommend using 12+ character passwords, 8- or 12-characters minimum passwords, rate-limiting to prevent infinite brute force attempts.**
- **This protection can be implemented by setting passwords for your OS account and if configurable setting the password policy depending on your OS.**
- **The fifth protection is firewall.**
- **This protection means ensuring that your firewall protects your device from any malicious packets that may try get into your device.**
- **I would recommend disabling all inbound traffic by default with exceptions for any local network services that you may need to use.**
- **You can also block vulnerable ports or use whitelisting for more robust filtering and protection on the network level.**

Threat Modelling Domain

- Threat modelling is the process of identifying who is realistically likely to target you.
- Threat modelling is important because it allows you to prepare against a real threat model and it prevents paranoia.
- There is a 5-step structure you can use for threat modelling
- The first step is to calm down.
- This step is where you reduce the emotional noise of the situation to ensure that you don't become paranoid by accident.
- This step can be done by taking deep breaths, releasing anger in a non-harmful way and other calming techniques.
- The second step is activity and value identification.
- This step is where you will be looking at your current digital activity and the value that you have.
- This step can be done by looking at the services and accounts you do, your job and how much money you make.
- This step is important because each threat actor targets a certain audience within a reason like for financial gain.
- The third step is research.
- This step is where you will be researching about different threat actors/models to find out motives and targets.
- This step can be done by reading my threat actor types document or other sources for threat actor types in Cybersecurity.
- This step is important because you can easily link a threat actor motive and targets to what you do and what your value is allowing you know your threat model.
- The fourth step is impact.
- This step is where you will be noting down the impact that this threat model can have on your life if they were to successfully compromise you.
- This step can be done by asking yourself what would be exposed? What accounts would I lose? How would this affect me daily?
- This step is important because it allows you to understand how successful compromise can disrupt your daily life.
- The fifth step is protection.
- This step is where you will be implementing protections based on the vectors that your threat model uses.
- This step can be done by using built-in security, third-party tools and behavioural habits.
- You can use information from my frameworks or other sources to understand more about protections and how to potentially implement them.
- This step is important because it allows you to protect yourself effectively.

Detection & Monitoring Domain

- **Detection & monitoring is the process of detecting a threat in real-time and actively scanning for one.**
- **Detection & monitoring is important because it ensures that not only security systems reactive but also proactive.**
- **There are 4 main protections that users can implement.**
- **The first protection is IDS/IPS systems.**
- **IDS stands for intrusion detection system which is used to detect threats on a network and alert an admin. It does not prevent threats.**
- **IPS stands for intrusion prevention system which is used to prevent intrusion threats on a network.**
- **I would recommend using IPS for a balance of detection and prevention while using IDS for just detection.**
- **You can implement this protection by using software such as Snort, Suricata or Zeek for IDS/IPS on Windows or Linux.**
- **The second protection is email-based login alerts.**
- **Email-based login alerts are alerts sent to your email when security actions such as account logins or password resets occur.**
- **I would recommend using email-based login alerts for sensitive account but with caution that an attacker may send fake login alerts.**
- **You can handle fake login alerts using my phishing detection system if needed as it is designed against an attacker tricking you.**
- **You can implement this protection by heading to account settings specifically security and checking if the service supports email-based logins.**
- **The third protection is using operating system logs.**
- **Operating system logs are security logs stored by the system with information such as login status, timestamps and security actions.**
- **I would recommend using Event viewer and Windows Defender logs on Windows, Console.app and security logs on MacOS and Syslog and Auth.log for Linux although across Linux distributions this may vary.**
- **You can implement these tools by using the device settings or entering certain commands on terminals.**
- **The fourth protection is next-generation firewall otherwise known as NGFW.**
- **Next-generation firewalls are firewall with detection and monitoring capabilities like behavioural analysis, real-time alerts and malware file detection.**
- **I would recommend using PA Series, FortiGate or Firepower for the NGFW However remember that Next-gen firewalls are an advanced detection tool.**
- **Make sure to only use advanced protections if the threat model calls for it as they are expensive and mentally draining to maintain.**
- **Other advanced protections include SIEM, AI-driven detection and NDR.**

Access Control Domain

- Access control is the process of controlling access to certain data or parts of the system.
- Access Control is important because without it, anyone within the system has unlimited access within the system.
- There are 4 main protections that users or companies can implement
- The first protection is admin and user separation.
- This means using a standard user account for daily usage instead of admin account for daily usage.
- This is important because it reduces the blast radius of malware compromising the device as a standard user does not have admin-level permissions.
- This protection can be implemented by creating a standard account on Windows and avoiding using root permissions on Linux. This protection cannot be done on MacOS.
- The second protection is RBAC.
- RBAC stands for role-based access control which assigns permissions based on role and not by user.
- This is important because it ensures that users can only access certain types of data based on their role ensuring control over the flow of data.
- This protection can be implemented by using the domain-control on Windows enterprise versions or implementing permissions on websites.
- The third protection is principle of least privilege.
- This means giving users permissions based on what's needed for the role nothing more and nothing less.
- This principle can also apply for third-party software or tools ensuring that it only has the permissions needed to do its role and nothing more.
- This is important because it means no staff member can access more than they are allowed to and third-party tools cannot easily be used in supply chain attacks against the security system.
- This can be implemented through windows domain-control, website specific permissions and controlled app/third-party permissions
- The fourth protection is time-based or session-based access.
- This means making a limited amount of time that a user can use their account or providing one session of access for a user.
- This is important because it ensures that an attacker cannot maintain persistent access to an account or that third-party contractors have perm access.
- This protection can be implemented by setting session duration per roles and creating a temporary account for third-party contractors to work.
- This domain of access control is mainly created for companies as they have larger networks and more people.
- For users, admin and user separation is the best they can do for access control.

Personal Contingency Planning Structure

- This contingency planning is designed to help individuals to create their own contingency plan for data breach within their personal systems.
- This personal contingency planning structure has 7 steps.
- The first step is to calm down.
- This is where you will be reducing the emotional noise of the data breach as it can be quite stressful or frustrating.
- This can be done by taking deep breaths, releasing anger in a non-harmful way or using other calming techniques.
- This step is important to ensure that you aren't as stressed, anxious or angry which can cause mistakes making the situation worse.
- The second step is identifying.
- This is where you will be looking at what the data breach situation for information gathering purposes.
- This can be done by asking yourself questions such as what was breached? What systems are compromised? What type of attack was used?
- The third step is containment.
- This is where you will be taking action to isolate the breach or compromise to a specific device or account.
- This can be done by disconnecting your device from the internet or changing passwords of account that were linked to the compromised account.
- The fourth step is securing backups.
- This is where you will be preserving and protecting any clean data you must prevent compromise and prepare for recovery.
- This can be done by checking backups in cloud storage, physical drives or in other backup locations to check for compromise.
- The fifth step is research.
- This is where you will be looking at your options for recovery and actions you can take next to deal with the breach.
- This can be done by looking at available security knowledge you may have downloaded on another device, web searching or asking AI for assistance.
- The sixth step is recovery.
- This is where you will be attempting to recover your systems from the data breach or compromise.
- This can be done by using recovery methods such as backup recovery codes, recovery kits and other recovery methods you may have available.
- The seventh step is documentation
- This is where you will be documenting the data breach and your response to it.
- This can be done through the structure what → why → how → threat model → response → potential improvements.
- This step is important to create a feedback loop for a data breach to learn.

Organisation Contingency Planning Structure

- This organisation contingency planning structure is designed to help organisations create contingency plans for the case of data breach.
- This contingency planning structure has 7 steps.
- The first step is identifying
- This is where companies or more specifically CSIRT gather information in real-time on the situation.
- This can be done by looking at security logs from detection systems such SIEM, IDS, IPS or through employees reporting a potential data breach.
- The second step is containment
- This is where CSIRT moves to ensure that the data breach is isolated to a specific system to prevent it spreading further.
- This can be done by disconnecting devices from the internet, changing account passwords or rotating encryption keys.
- The third step is organising.
- This is where the company organises their employees into clear roles and responsibilities to handle the data breach.
- This can be done by allowing CSIRT to handle containment and compromise, IT to handle recovery and the social media team to handle public notification.
- The fourth step is internal investigation.
- This is where the company investigates the data breach internally to find out what happened.
- This can be done by reviewing security logs are the time of the intrusion, interviews employees, looking at behavioural patterns and calling law enforcement if necessary.
- The fifth step is public notification.
- This is where the company alerts the public of the data breach and gives them actions to take for their own security.
- This can be done by making posts on official social media accounts or sending emails with information about breach that users should know.
- The sixth step is recovery.
- This is where the company attempts to recover the compromised or breached system using recovery methods.
- This can be done by using admin-based recovery, full installation of an operating system via USB, physical drives or cloud storage.
- The seventh step is documentation.
- This is where the company documents the data breach and their response to the situation.
- This can be done via the structure what → why → how → threat model → response (Talk about role organisation, public notification and recovery) → potential improvements.

Human Layer Section

- One of the main principles of this architecture is that security systems should work with humans instead of against them.
- This means that robust security systems use a mixture human detection and judgement and technical measures and SafetyNet that catch human error.
- This is important because it means that a person is more likely to treat security as part of their life instead of an additional task they must do.
- I will discuss an example where the user's threat model is script kiddie and design a human-centric system.
- First, the user downloads and configures a password manager and sets a passphrase for easier memory.
- Second, the user changes all their account's passwords to 16-character unique passwords which are stored in their password manager.
- Third, the user uses the password manager as a browser extension for quicker and easier access.
- Fourth, the user sets up MFA via authentication app on as many accounts as they can and uses email-based MFA where they can't.
- Fifth, the user stays logged into their most frequently used accounts via cookies or using apps.
- This example shows that user can balance convenience and security when your threat model is script kiddie.
- However, it is important to remember at high threat models such as nation-state or organised cybercriminals that convenience comes at the cost of security.
- It is also important the people have a quick decision framework they can follow in case of unexpected situations.
- This quick decision framework has 3 options.
- The first option is logical approach.
- This is where you follow pre-made steps that are adaptable but logical for each situation you could face.
- For example, you may use the structure Identify → Verify → Act for security situations as it is simple to remember but logical.
- The second option is waiting approach.
- This is where you wait and be patient instead of reacting which can be impulsive can make the situation worse.
- For example, in a device theft, instead of trying to stop the person who could have a weapon you wait. You can then do a remote wipe or report the situation.
- This is important because your life is more important than any digital assets you could possibly have.
- The third option is trust-based.
- This is where you trust someone else like a family member, partner or friend to help you with an unexpected situation.

Security System Example

- This security system example will use the threat models of script kiddies, opportunistic attackers and insider threats.
- The user in this example will have a Windows 11 home operating system and will be shown implementing protections across domains.
- First, the user installs and configures Bitwarden using a 5–6-word passphrase for their master password.
- Second, the user installs Microsoft authenticator on their phone and configures MFA for their Bitwarden account.
- Third, the user changes all their account passwords to 16-character unique passwords that are stored in Bitwarden.
- The user sets up the Bitwarden Extension on chrome for easier access and daily account usage.
- Fourth, the user sets up MFA for all accounts via Microsoft authenticator or their email if authentication app isn't support.
- Fifth, the user stores backup recovery codes in encrypted cloud storage and on their device using 7-zip encryption.
- Sixth, the user sets up email-based login alerts for accounts that require email for real-time detection.
- Seventh, the user creates a secondary Gmail account and switches a few account emails to use that account.
- This means that the user doesn't have a single point of failure within their accounts as an attacker cannot use one email.
- Eighth, the user heads into their device settings and turns on device encryption encrypting the data on their device.
- Ninth, the user turns on automatic updates and sets the update hours to be during when they aren't active.
- These automatic updates are turned on for Windows Itself and any firmware or BIOS updates that may come through.
- Tenth, the user configures windows defender to ensure that real-time protection is on, and everything is set up correctly.
- Eveleth, the user sets up admin and standard user separation by creating two accounts on their device.
- Twentieth, the user configures their router to use WPA3-personal with a 24-character password.
- Thirteenth, the user sets a strong admin router password which is a 6-word passphrase for memory.
- Finally, the user finishes off by turning off remote management and WPS on their network.
- This workflow above shows what protections a user would implement exactly across all domains except for threat modelling itself.

Security Architecture Trade-Offs

- **This security architecture has trade-offs just like any system I have created so far.**
- **Users or companies may face further implementation challenges due to infrastructure or resources limitations.**
- **I have identified 5 main trade-offs with this security architecture.**
- **The first trade-off is time-consumption.**
- **This trade-off exists because it can take a lot of time to set up and implement security features across 7-8 domains.**
- **This means that it may not be possible for some users or companies to implement all recommended protections due to busy schedules.**
- **This trade-off can be managed by implementing the easiest features, using time management methods such as time-blocking and working in teams if possible.**
- **The second trade-off is complexity.**
- **This trade-off exists because some security features such as IDS/IPS systems, admin/user separation and others can be confusing and hard to set up.**
- **This means that users and companies may not configure security protections correctly or may not be able to do so at all.**
- **This trade-off can be managed by structured learning processes, looking at guides and starting with the easiest features to implement.**
- **The third trade-off is convenience.**
- **This trade-off exists because with the more security features you implement the more convenience you lose.**
- **This means that some security systems especially ones designed for nation-state actors will not be sustainable and will remove convenience from your life.**
- **This trade-off can be managed by using secure but easy use to use security features like password manager browser extension or being logged into apps.**
- **The fourth trade-off is lack of specialization**
- **This trade-off exists because this security architecture covers basic and some advanced protections in each domain.**
- **This means that users and companies may not have the detail or knowledge from this documentation to set up security systems in a specific domain.**
- **This trade-off can be managed by looking at my more specialised frameworks like network security framework or threat actor types document.**
- **The fifth trade-off is risk of paranoia.**
- **This trade-off exists because if you are someone with a history of being anxious then you may want to try close every gap.**
- **This means that some users will be paranoid and will create security systems that are unsustainable and could potentially harm a user's mental health.**
- **This trade-off can be managed by calming down before designing and implementing security system and using threat modelling.**